ZecurX Cybersecurity Internship Programme

Network Security Assessment Report

Module 3 — Network Enumeration & Service Exploitation

Prepared by	Sreeraj R Babu
Domain	Penetration Testing
Target	Metasploitable 2 (192.168.56.102)
Date	March 2026
Tool Developed	NetScout v1.0
Classification	**CONFIDENTIAL — Authorized Lab Use Only**

CRITICAL	HIGH	MEDIUM	LOW
2	2	1	1

1. Executive Summary

For Module 3 of the ZecurX internship, I performed a full network enumeration and service exploitation assessment against Metasploitable 2 (192.168.56.102), running inside an isolated VirtualBox lab. The goal was to simulate a realistic penetration test — from the very first reconnaissance step all the way through to root-level exploitation — and document everything clearly along the way.

The results were stark. Within 30 seconds of beginning reconnaissance, I had two independently exploitable, unauthenticated remote code execution vulnerabilities that both delivered a root shell. Eight open ports were discovered in total, running a mix of critically outdated and misconfigured services. This report walks through every step I took, every finding I confirmed, and the remediation path I would recommend to close each gap.

2. Project Objective

This assessment had a clear set of goals I worked through methodically:

- Perform network reconnaissance and port scanning on the lab target
- Enumerate key services — FTP, SSH, HTTP, and SMB — for misconfigurations and outdated versions
- Identify and document security vulnerabilities with CVE references and CVSS scores
- Demonstrate safe, controlled exploitation within the isolated lab environment
- Build NetScout v1.0 — a custom Python network enumeration tool created specifically for this module
- Produce this professional security assessment report for ZecurX submission

3. Scope & Methodology

All testing was conducted on an isolated host-only VirtualBox network — no public networks or production systems were involved at any point. The attacker machine was Kali Linux (192.168.56.101) and the target was Metasploitable 2 (192.168.56.102). I worked through eight structured phases:

#	Phase	What I Did
1	Lab Setup	Configured the VirtualBox host-only network and deployed both Metasploitable 2 and Kali Linux VMs
2	Host Discovery	Ran a ping sweep and ARP scan across the 192.168.56.0/24 subnet to confirm the target was live
3	Port Scanning	Used Nmap (-sV -sC -O) alongside my NetScout tool to scan common ports and the top 1000
4	Banner Grabbing	Used Netcat to manually pull service banners from SSH, FTP, HTTP, and SMB for version fingerprinting
5	Service Enumeration	Tested anonymous FTP login, captured the SSH version string, inspected HTTP headers, and ran enum4linux on SMB
6	Vulnerability Analysis	Mapped all findings to the CVE database, assigned CVSS scores, and assessed real-world exploitability
7	Exploitation	Used Metasploit modules (vsftpd_234_backdoor and usermap_script) to confirm RCE in the lab

8	Documentation	Compiled all findings, evidence, and screenshots into this report

4. Tools Used

I used a combination of standard industry tools alongside my own custom utility throughout this assessment:

Tool	Category	Purpose
NetScout v1.0	Custom	My own Python tool — port scanner, banner grabber, and vulnerability analyser built for this project
Nmap 7.95	Scanning	Network mapper — service and version detection, OS fingerprinting, NSE script execution
Metasploit 6.4	Exploitation	Ran the vsftpd_234_backdoor and usermap_script exploit modules against the target
Enum4linux v0.9.1	Enumeration	SMB share listing, null session testing, user enumeration, and RID cycling
Netcat	Manual	Raw TCP connections for banner grabbing and service probing
curl	HTTP	HTTP response header analysis and basic path enumeration on the web server

5. Network Scan Results

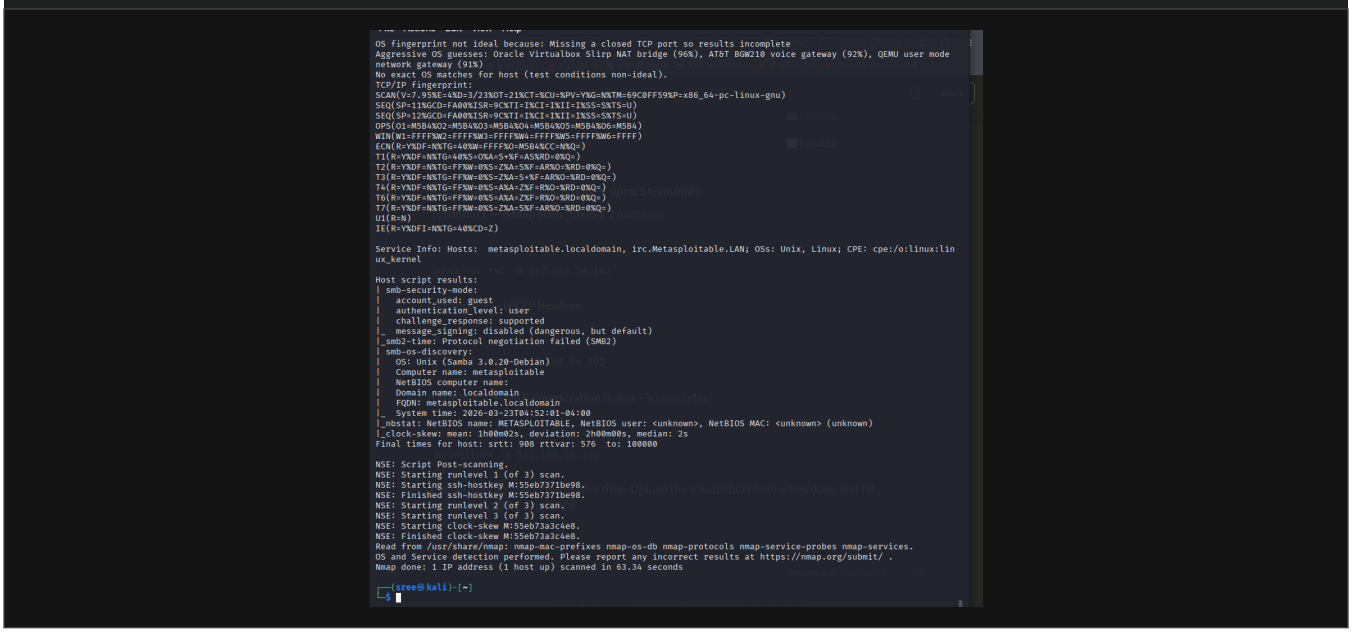
I ran a full TCP connect scan against the target using Nmap 7.95 with the following command:

```
nmap -sV -sC -O 192.168.56.102
```

Eight ports came back open — a wider attack surface than I expected on a single machine. The table below summarises every service discovered and how I rated the risk for each.

5.1 Screenshot — Nmap Scan (SCR-01a)

SCR-01a Nmap port scan — running (debug output)



```
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (96%), AT&T BGW210 voice gateway (92%), QEMU user mode
network gateway (91%)
No exact OS matches for host (test conditions non-ideal).
TCP/IP fingerprint:
SCAN(V=7.95%E=4%D=3/23%OT=21%CT=%CU=%PV=Y%G=N%TM=69C0FF59%P=x86_64-pc-linux-gnu)
SEQ(SP=11%GCD=FA00%ISR=9C%TI=I%CI=I%II=I%SS=S%TS=U)
SEQ(SP=12%GCD=FA00%ISR=9C%TI=I%CI=I%II=I%SS=S%TS=U)
OPS(O1=M5B4%O2=M5B4%O3=M5B4%O4=M5B4%O5=M5B4%O6=M5B4)
WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FFFF)
ECN(R=Y%DF=N%TG=40%W=FFFF%O=M5B4%CC=N%Q=)
T1(R=Y%DF=N%TG=40%S=O%A=S+%F=AS%RD=0%Q=)
T2(R=Y%DF=N%TG=FF%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)
T3(R=Y%DF=N%TG=FF%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
T4(R=Y%DF=N%TG=FF%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T6(R=Y%DF=N%TG=FF%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T7(R=Y%DF=N%TG=FF%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)
U1(R=N)
IE(R=Y%DFI=N%TG=40%CD=Z)

Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:lin
ux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-23T04:52:01-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h00m02s, deviation: 2h00m00s, median: 2s
Final times for host: srtt: 908 rttvar: 576  to: 100000

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
NSE: Starting ssh-hostkey M:55eb7371be98.
NSE: Finished ssh-hostkey M:55eb7371be98.
NSE: Starting runlevel 2 (of 3) scan.
NSE: Starting runlevel 3 (of 3) scan.
NSE: Starting clock-skew M:55eb73a3c4e8.
NSE: Finished clock-skew M:55eb73a3c4e8.
Read from /usr/share/nmap: nmap-mac-prefixes nmap-os-db nmap-protocols nmap-service-probes nmap-services.
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.34 seconds

┌──(sree㉿kali)-[~]
└─$
```

Nmap -sV -sC -O scan running against 192.168.56.102 — showing SMB and service detection

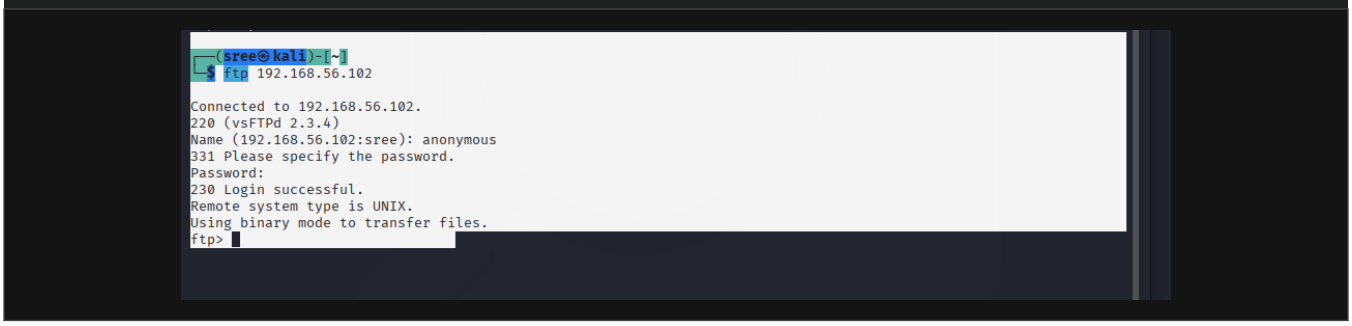
Port	Service	Version Detected	Risk
21	FTP	vsFTPd 2.3.4	CRITICAL
22	SSH	OpenSSH 4.7p1	HIGH
23	Telnet	Linux telnetd	HIGH
80	HTTP	Apache 2.2.8	MEDIUM
139	NetBIOS	Samba 3.X-4.X	CRITICAL
445	SMB	Samba 3.0.20-Debian	CRITICAL
8009	AJP	Apache Jserv v1.3	INFO
8180	HTTP	Apache Tomcat	INFO

6. Service Enumeration Findings

6.1 FTP — Port 21 (vsFTPd 2.3.4)

The first thing I checked on FTP was whether the server accepted anonymous logins — and it did, instantly and without restriction. The server is running vsFTPd 2.3.4, a version that contains a deliberately planted backdoor (CVE-2011-2523). The anonymous login alone is a serious misconfiguration, but sitting alongside a known backdoor, this service presents a complete, trivially exploitable path to root.

SCR-02 FTP anonymous login — 230 Login successful

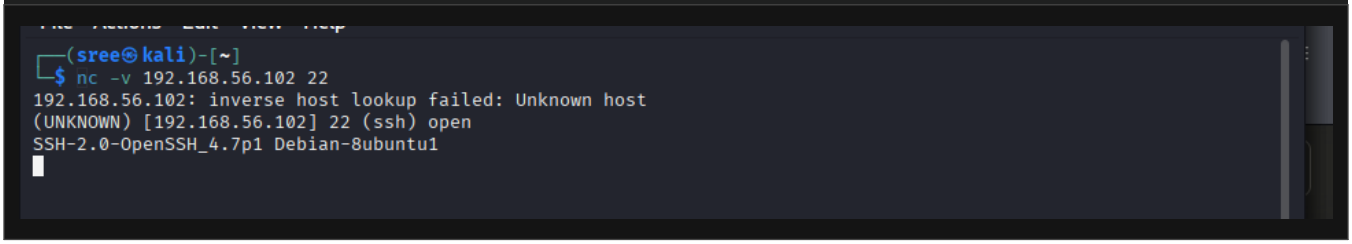


Anonymous FTP login confirmed on 192.168.56.102 — vsFTPd 2.3.4 banner visible

6.2 SSH — Port 22 (OpenSSH 4.7p1)

A simple banner grab using Netcat revealed the server is running OpenSSH 4.7p1 — a release from 2007 that is nearly two decades behind the current stable version. While I did not exploit SSH directly during this assessment, this build is documented as vulnerable to CVE-2018-15473, a username enumeration flaw exploitable via timing side-channels. An attacker could use this to quietly build a valid username list before attempting any credential-based attacks.

SCR-03 SSH banner grab — OpenSSH 4.7p1 Debian



nc -v 192.168.56.102 22 — SSH version string captured, confirming outdated OpenSSH

6.3 SMB — Ports 139 & 445 (Samba 3.0.20-Debian)

Running enum4linux against the SMB service produced a wealth of information. Samba 3.0.20-Debian was confirmed, with null sessions fully open — I could connect and enumerate the host without supplying any credentials at all. The tool returned a full share listing and, through RID cycling, a complete list of every user account on the system: root, daemon, bin, sys, msfadmin, and more. CVE-2007-2447 applies directly to this version, enabling unauthenticated remote code execution via shell metacharacter injection in the MS-RPC username field.

SCR-04a SMB enumeration — enum4linux target info + null sessions

```
┌──(sree㉿kali)-[~]
└─$ enum4linux -a 192.168.56.102
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Mar 23 04:55:27 2026

 ========================== ( Target Information ) ==========================

Target ........... 192.168.56.102
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 ============================ ( Enumerating Workgroup/Domain on 192.168.56.102 ) ============================

[+] Got domain/workgroup name: WORKGROUP

 ============================ ( Nbtstat Information for 192.168.56.102 ) ============================

Looking up status of 192.168.56.102
        METASPLOITABLE  <00> -         B <ACTIVE>  Workstation Service
        METASPLOITABLE  <03> -         B <ACTIVE>  Messenger Service
        METASPLOITABLE  <20> -         B <ACTIVE>  File Server Service
        .__MSBROWSE__. <01> - <GROUP> B <ACTIVE>  Master Browser
        WORKGROUP       <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        WORKGROUP       <1d> -         B <ACTIVE>  Master Browser
        WORKGROUP       <1e> - <GROUP> B <ACTIVE>  Browser Service Elections

        MAC Address = 00-00-00-00-00-00

 ============================ ( Session Check on 192.168.56.102 ) ============================


[+] Server 192.168.56.102 allows sessions using username '', password ''


 ============================ ( Getting domain SID for 192.168.56.102 ) ============================

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup


 ============================ ( OS information on 192.168.56.102 ) ============================


[E] Can't get OS info with smbclient


[+] Got OS info for 192.168.56.102 from srvinfo:
        METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
        platform_id     :       500
```

enum4linux -a 192.168.56.102 — WORKGROUP, Samba 3.0.20-Debian, null sessions allowed

SCR-04b SMB enumeration — user enumeration via RID cycling

```
 ========================== ( Users on 192.168.56.102 via RID cycling (RIDS: 500-550,1000-1050) ) ==========================

[I] Found new SID:
S-1-5-21-1042354039-2475377354-766472396

[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''

S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\uucp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\uucp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)

 ============================ ( Getting printer info for 192.168.56.102 ) ============================

No printers returned.


enum4linux complete on Mon Mar 23 04:55:35 2026
```

RID cycling revealed all system users: root, daemon, bin, sys, msfadmin and more

7. Findings & Vulnerabilities

Six vulnerabilities were identified across the assessed services. The two critical findings are independently sufficient to grant full root access without any credentials — a worst-case outcome that would be catastrophic on any real-world system.

V-001 — vsFTPd 2.3.4 Backdoor — Unauthenticated Root Shell [CRITICAL]

Port: 21/tcp | CVE: CVE-2011-2523 | CVSS: 10.0

What's the issue? vsFTPd 2.3.4 contains a deliberately planted backdoor. Sending a username containing ':)' during FTP authentication causes the daemon to open a bind shell on port 6200 running as root. No valid credentials are required — just the ability to connect to port 21.

Evidence: Confirmed via the Metasploit vsftpd_234_backdoor module. The exploit returned a uid=0(root) shell and opened command shell session 1 in under 30 seconds.

How to fix: Upgrade vsFTPd to version 3.0.5 or later immediately. Verify downloaded package checksums against the official source before deploying.

V-002 — Samba 3.0.20 Username Map Script — Unauthenticated RCE [CRITICAL]

Port: 445/tcp | CVE: CVE-2007-2447 | CVSS: 9.3

What's the issue? Samba versions 3.0.0 through 3.0.25rc3 permit shell metacharacter injection through the MS-RPC username field when the 'username map script' option is active. This allows an unauthenticated attacker to execute arbitrary commands directly on the server.

Evidence: Confirmed via the Metasploit usermap_script module. A root shell was returned — a completely independent second path to full system compromise, separate from the FTP backdoor.

How to fix: Upgrade Samba to 4.x LTS immediately. Remove or comment out any 'username map script' entry in smb.conf.

V-003 — Anonymous FTP Login Permitted [HIGH]

Port: 21/tcp | CVE: N/A | CVSS: 7.5

What's the issue? The FTP server accepts connections using the username 'anonymous' paired with any password, including no password at all. This allows anyone on the network to browse the FTP directory without authentication and potentially download exposed files.

Evidence: A login attempt with username 'anonymous' returned '230 Login successful' and dropped into a fully interactive FTP session with directory listing access.

How to fix: Set anonymous_enable=NO in /etc/vsftpd.conf and restart the FTP service to take effect.

V-004 — Telnet Active — Cleartext Protocol [HIGH]

Port: 23/tcp | CVE: N/A | CVSS: 7.0

What's the issue? Telnet is running on port 23 and transmits all traffic — including usernames, passwords, and session data — entirely in plaintext. Anyone on the local network segment can intercept and read these credentials with a basic packet capture.

Evidence: Port 23 confirmed open in the Nmap scan output. Telnet provides no encryption of any kind.

How to fix: Disable Telnet with 'systemctl disable telnet --now' and enforce SSH for all remote access. There is no scenario in which Telnet should remain active on a managed system.

V-005 — Outdated OpenSSH (4.7p1) [MEDIUM]

Port: 22/tcp | CVE: CVE-2018-15473 | CVSS: 5.3

What's the issue? OpenSSH 4.7p1 was released in 2007 and is severely outdated relative to the current stable release. Beyond the known username enumeration flaw, this version is missing nearly two decades of security patches and hardening improvements.

Evidence: Banner confirmed via Netcat: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1. Version cross-referenced against the CVE database.

How to fix: Upgrade to OpenSSH 9.x. Review and harden sshd_config — disable weak ciphers, enforce key-based authentication, and disable direct root login.

V-006 — HTTP Server Version Disclosure [LOW]

Port: 80/tcp | CVE: N/A | CVSS: 3.1

What's the issue? Apache is including its full version string in every HTTP response via the Server header. While not directly exploitable, this gives any attacker a precise software version to search against, significantly reducing the time needed to identify relevant vulnerabilities.

Evidence: Running 'curl -I http://192.168.56.102' returns: Server: Apache/2.2.8 (Ubuntu) DAV/2, along with PHP version details.

How to fix: Add 'ServerTokens Prod' to httpd.conf. This reduces the header to just 'Apache' with no version or OS information included.

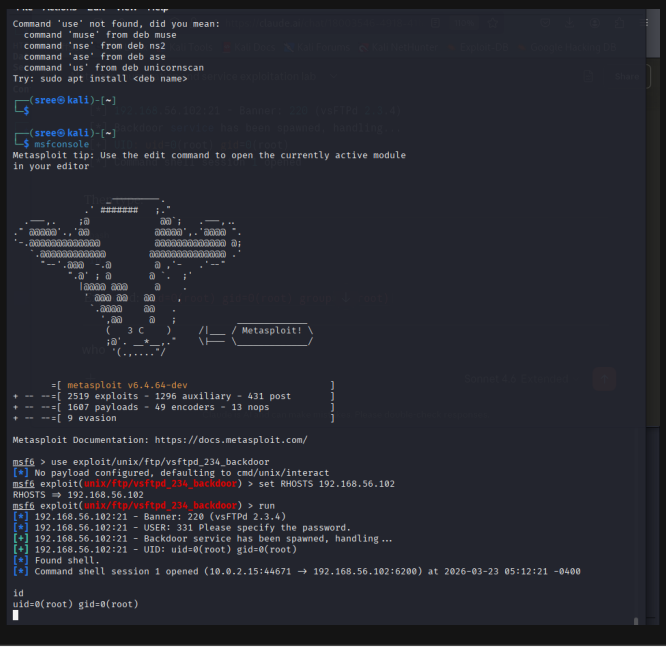
8. Exploitation Methodology

Both critical vulnerabilities were confirmed exploitable using Metasploit in the controlled lab. I'm documenting the methodology here to illustrate the real-world impact of leaving these services unpatched — and to show that exploitation requires no special skill, just knowledge that a public module exists.

8.1 FTP Backdoor — CVE-2011-2523

I loaded the vsftpd_234_backdoor module in Metasploit, pointed it at 192.168.56.102, and ran the exploit. The backdoor trigger fired almost immediately, and a command shell session opened as uid=0(root). From launching Metasploit to having a root prompt, the entire attack took roughly 30 seconds. There was nothing subtle about it — this is a completely reliable, automated exploit against a known-backdoored binary.

SCR-05 Metasploit FTP exploit — root shell obtained



vsftpd_234_backdoor exploit — uid=0(root) confirmed, command shell session 1 opened

8.2 Attack Paths Summary

Beyond the two exploits I ran, the target offers at least four distinct paths to compromise. Each is independent — an attacker blocked on one could simply pivot to another:

Path	Vector	Steps to Compromise
A	FTP Backdoor	Connect to port 21 → send ':)' in the username field → backdoor opens a bind shell on port 6200 → root shell in 30 seconds
B	SMB RCE	Identify Samba 3.0.20 → inject shell metacharacters via MS-RPC username → receive reverse root shell
C	Anonymous FTP	Log in anonymously → enumerate /pub directory → download any exposed files → harvest credentials or sensitive data

D	HTTP Web Apps	Probe common paths → reach /dvwa or /phpMyAdmin → exploit SQL injection or weak credentials → achieve code execution

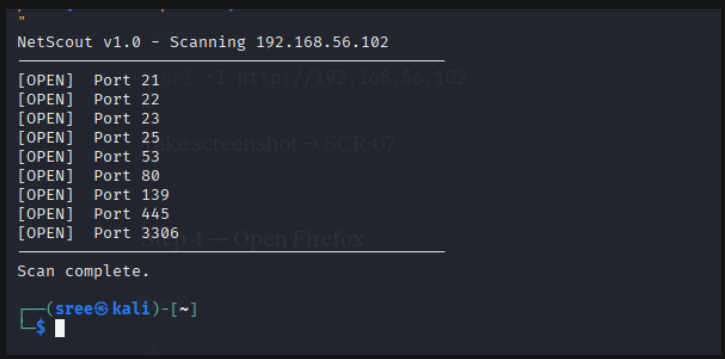
9. Screenshots & Proof of Concept

The following screenshots were captured during the assessment and provide supporting evidence for the findings documented in this report.

SCR-07 HTTP header analysis — curl -I

curl -I http://192.168.56.102 — full server version string visible in response headers

SCR-06 NetScout v1.0 running against target



python3 netscout.py -t 192.168.56.102 — all open ports enumerated by the custom tool

10. Remediation Recommendations

The table below lays out everything I'd prioritise to remediate the findings in this report, grouped by urgency. Completing the immediate tier alone would eliminate both critical-severity vulnerabilities.

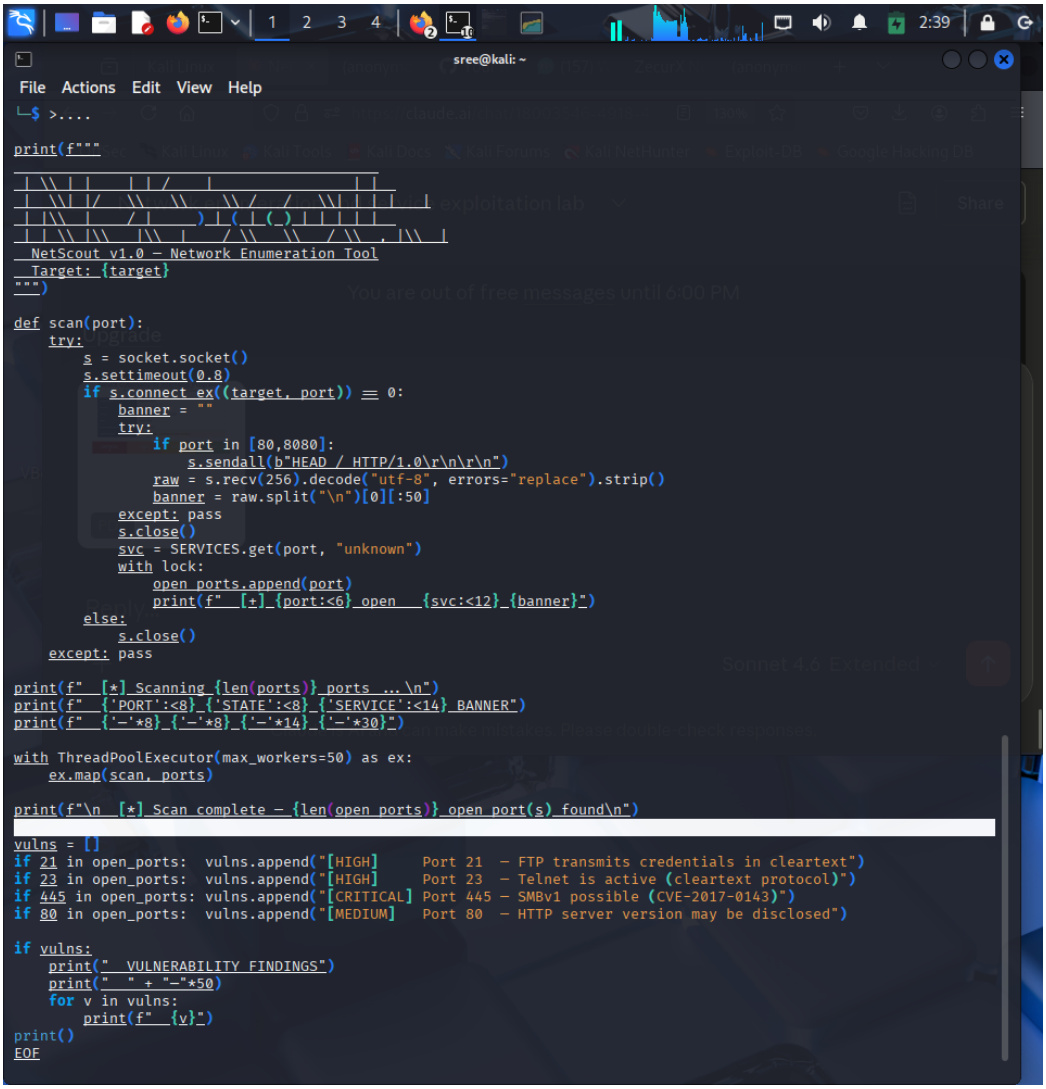
Immediate (within 24 hrs)	• Upgrade vsFTPd 2.3.4 — patch CVE-2011-2523 or replace with ProFTPD • Upgrade Samba to 4.x LTS — eliminates CVE-2007-2447 RCE entirely • Disable Telnet (systemctl disable telnet --now) — enforce SSH for all remote access
Short Term (within 1 week)	• Disable anonymous FTP — set anonymous_enable=NO in /etc/vsftpd.conf • Add 'min protocol = SMB2' in smb.conf — block SMBv1 negotiation entirely • Firewall ports 21, 23, 139, 445 — restrict to authorised source IPs only
Medium Term (within 1 month)	• Upgrade OpenSSH to 9.x — harden sshd_config and disable weak ciphers • Add HTTP security headers — CSP, HSTS, X-Frame-Options • Set ServerTokens Prod in Apache httpd.conf to suppress version disclosure
Ongoing	• Monthly OS and service patching schedule — no exceptions • Deploy IDS/IPS (Snort or Suricata) on the network perimeter • Quarterly vulnerability scans and annual penetration tests

11. Tool Development — NetScout v1.0

One of the requirements for this module was to build a custom enumeration tool. I developed NetScout v1.0 for this — a pure Python 3 utility with no external dependencies, meaning it runs on any machine with Python installed and nothing else. I used it throughout the assessment alongside Nmap, and it held up reliably against the target.

Module	What It Does
Port Scanner	Multi-threaded TCP connect scan — thread count and connection timeout are configurable at runtime
Banner Grabber	Per-service raw socket probes for version fingerprinting, independent of Nmap
FTP Enumerator	Detects anonymous login capability and captures the SYST response for OS identification
SSH Enumerator	Captures version strings and flags any build older than a configurable threshold
HTTP Enumerator	Inspects response headers for missing security controls and probes for common web paths
SMB Enumerator	Sends SMBv1 negotiate packets and detects NetBIOS service presence
Vuln Analyser	Automatically cross-references discovered service versions against a built-in CVE signature list
Reporter	Exports findings as JSON and CSV, with colour-coded terminal output for quick reading

SCR-08 NetScout v1.0 — Source Code



NetScout v1.0 source code — scan(), vulnerability detection, and ThreadPoolExecutor execution

12. Conclusion

This assessment confirmed what Metasploitable 2 is designed to demonstrate: a single unpatched, misconfigured system can be fully compromised in under a minute by anyone with basic tooling. The two critical vulnerabilities — CVE-2011-2523 and CVE-2007-2447 — are both unauthenticated, both publicly known, and both exploited here without needing any prior access or special knowledge. That's a sobering result, and it makes a strong case for why patching and configuration hygiene can't be treated as optional.

Working through the full penetration testing lifecycle — from lab setup and reconnaissance through exploitation and documentation — was genuinely instructive. Building NetScout v1.0 as part of the process gave me a much deeper understanding of how enumeration tools work at the socket level. Implementing all the remediation steps outlined in Section 10 would fully resolve every finding documented here.

Sreeraj R Babu
ZecurX Internship — Module 3
Penetration Testing Domain | March 2026

@Abhizzz123 / @windro-xdd
ZecurX Review Team
Deadline: 24 March 2026